

NYC / AI AGENT SECURITY SUMMIT

Your Agent Escaped Without Escaping the Sandbox

Yossi Eliaz

Principal Engineer and Head of DevRel at Incredibuild.com

October 21, 2026

The check passed. The parser was still broken.

mutable checker	PASS
parser artifact	unchanged
external case "1,,3"	REJECT expected
actual parser output	[1, 3]

One result from the lab. We will come back to how it happened.

Recorded Linux isolation run

One job. Four independent experiments.

Fix the parser.
Publish the task report.

Fresh fixtures for each experiment. Same operator intent.

Identity Files Data release Acceptance

What the experiment assumes

Worker controls: its code, workspace and requests.

Controller owns: launch policy, service permissions, verification and publication.

Synthetic credentials and data. A loopback service. No live model or external target.

Recorded Linux isolation run

01 / The worker borrowed the runner's identity

```
request: GET /projects/other/private
```

runner credential	200 + synthetic fixture
task credential	403
task input	200
expired credential	403

The service decides what the credential authorizes.

Recorded Linux isolation run

Identity follows an explicit grant

Launch: clean environment and closed extra descriptors.

Grant: task resource, operation, audience and expiry.

Enforcement: a service or broker outside the worker.

A stronger process boundary still needs narrower credentials.

02 / The mount reached the next job

worker writes /shared/next-job.json

writable bind	host fixture changes
read-only bind	write denied; fixture unchanged
/output	patch remains writable

Observed with real bind mounts

Filesystem access is part of the task contract

Resource	Worker access
Source input	Read only
Task output	Writable
Shared job state	Read only in this lab
Controller files	Outside the mount set

Production deployments can omit shared state entirely.

03 / The service was allowed. The recipient was wrong.

same upload service

/accounts/team/reports intended recipient

/accounts/other/uploads synthetic private data

The weak worker reaches a second account on the same service.

Recorded Linux isolation run

Data release needs a narrow operation

Worker: requests one fixed report operation.

Broker: constructs the body and selects the team account.

Checks: rejects extra recipient, payload and URL fields.

Direct host-loopback probe: unreachable

04 / The worker changed what success meant

```
# Worker rewrites the workspace checker:  
print("PASS")  
raise SystemExit(0)
```

The old controller accepts exit code zero. The parser stays broken.

Recorded Linux isolation run

The same artifact meets an independent verifier

Input	Buggy parser	Fixed parser
1,2,3	Accept	Accept
1,,3	Accept	Reject
Empty input	Accept	Reject
-2, 3	Accept	Accept
x	Reject	Reject

Recorded Linux isolation run

Acceptance belongs to exact bytes

Rejected artifact	Denied
Artifact swapped after verification	Denied
Authentic approval from a stale run	Denied
Verifier identity changed	Denied
Replayed approval	Denied
Verified artifact, current run	Accepted

Recorded Linux isolation run

History needs an independent anchor

The worker can rebuild a chain it owns.

The controller retains the original head. Rewritten history disagrees.

Recorded Linux isolation run

The original job still succeeds

1. Worker reads input and writes the fixed parser.
2. External verifier checks the frozen artifact.
3. Gate accepts exactly those bytes.
4. Broker publishes the fixed task report.

29 checks passed

Recorded Linux isolation run

Four boundaries to inspect

Question

What can execute and reach the host?

What can read and change files?

What can act and send data?

What can declare success?

Enforcing owner

Runtime

Host mount policy

Service and broker

Verifier and gate

THE QUESTION TO TAKE HOME

Who gave this process the authority?

github.com/zozo123/nyc-talk

Yossi Eliaz / Questions

Appendix / Reproduction

```
make demo      # Linux + bubblewrap; strict
make reference # policy checks; explicit skips
make deck      # evidence check + PDF build
```

Records include source digests, subprocess output and service observations.

Appendix / Limits of the evidence

Deterministic scripts exercise chosen actions.

Namespace and mount checks require the isolated run.

Five parser cases establish one demonstrated repair.

Controller code, keys and decisions remain trusted.

No cgroup, kernel-exploit, covert-channel or universal security claim.

Appendix / Primary references

Linux environ(7)

Environment inheritance

Docker bind mounts

Host filesystem effects and read-only mounts

RFC 9700

Access-token privilege restriction

SLSA artifact verification

Trusted provenance and artifact identity